

Extensión de los Scopes para Controlar Otros Endpoints de la API

Objetivo

El objetivo de esta fase fue extender el mecanismo de seguridad implementado previamente, incorporando un modelo de autorización basado en scopes específicos por recurso y método HTTP, permitiendo un control de acceso más granular sobre los endpoints del sistema.

Se buscó garantizar que:

- No todos los usuarios puedan ejecutar todas las operaciones.
- Las acciones estén limitadas según los permisos incluidos en el JWT.
- El sistema diferencie claramente entre autenticación (quién es el usuario) y autorización (qué puede hacer).

```
String scope;  
if(req.username().equals(anObject: "admin")){  
    scope = "blueprints.read blueprints.write users.admin reports.read";  
}else{  
    scope = "blueprints.read";  
}
```

Usuario **admin**:

- Puede consultar blueprints.
- Puede crear y modificar blueprints.
- Posee scopes adicionales administrativos.

Usuario estándar:

- Solo puede consultar blueprints (blueprints.read).

```
.authorizeHttpRequests(auth > auth
    .requestMatchers(...patterns: "/actuator/health", "/auth/login").permitAll()
    .requestMatchers(...patterns: "/v3/api-docs/**", "/swagger-ui/**", "/swagger-ui.html").permitAll()

    .requestMatchers(HttpMethod.GET, ...patterns: "/api/v1/blueprints/**")
    .hasAuthority(authority: "SCOPE_blueprints.read")

    .requestMatchers(HttpMethod.POST, ...patterns: "/api/v1/blueprints/**")
    .hasAuthority(authority: "SCOPE_blueprints.write")

    .requestMatchers(HttpMethod.PUT, ...patterns: "/api/v1/blueprints/**")
    .hasAuthority(authority: "SCOPE_blueprints.write")
```

Se actualizó la configuración de seguridad para aplicar validación de scopes según:

- Recurso (blueprints)
- Método HTTP (GET, POST, PUT, DELETE)
- Versión de API (/api/v1)

Admin

[illegible]

y f s
y

Request URL
http://localhost:8080/api/v1/blueprints/terra/planeterrario/points

Server response

Code	Details
202	Response body <pre>{ "code": 202, "message": "Point added", "data": null }</pre> Response headers <pre>cache-control: no-cache,no-store,max-age=0,must-revalidate connection: keep-alive content-type: application/json date: Thu, 26 Feb 2026 13:47:51 GMT expires: 0 keep-alive: timeout=60 pragma: no-cache transfer-encoding: chunked x-content-type-options: nosniff x-frame-options: DENY x-xss-protection: 0</pre>

Usuario normal

Request URL
http://localhost:8080/api/v1/blueprints

Server response

Code	Details
200	Response body <pre>{ "code": 200, "message": "execute ok", "data": [{ "author": "juan", "name": "plano", "points": [{ "x": 10, "y": 5 }] }, { "author": "felipe", "name": "plano", "points": [{ "x": 4, "y": 5 }, { "x": 1, "y": 1 }] }] }</pre> Response headers <pre>cache-control: no-cache,no-store,max-age=0,must-revalidate</pre>

Request URL
http://localhost:8080/api/v1/blueprints

Server response

Code	Details
403	Error: response status is 403 Response headers <pre>cache-control: no-cache,no-store,max-age=0,must-revalidate connection: keep-alive content-length: 0 date: Thu, 26 Feb 2026 13:49:51 GMT expires: 0 keep-alive: timeout=60 pragma: no-cache www-authenticate: bearer error="insufficient_scope",error_description="the request requires higher privileges than provided by the access token",error_uri="https://tools.ietf.org/html/rfc6750#section-3.1" x-content-type-options: nosniff x-frame-options: DENY x-xss-protection: 0</pre>

Responses

Code	Description	Links
201	Blueprint created successfully	No links

Media type
application/json

Request URL

http://localhost:8080/api/v1/blueprints/terra/planoterario/points

Server response

Code

Details

403

Unauthorized

Error: response status is 403

Response headers

cache-control: no-cache,no-store,max-age=0,must-revalidate

connection: keep-alive

content-length: 0

date: Thu, 26 Feb 2020 13:50:16 GMT

expires: 0

keep-alive: timeout=60

pragma: no-cache

www-authenticate: Basic error="insufficient_scope",error_description="the request requires higher privileges than provided by the access token",error_uri="https://tools.ietf.org/html/rfc6750#section-3.1"

x-content-type-options: nosniff

x-frame-options: DENY

x-xss-protection: 0

Responses

Code

Description

Links

202

Point added successfully

No links